

Rédaction de Rapports pour Incidents et Crises

Sommaire

1. Enjeux et contexte de la rédaction
2. Phases de rédaction dans la gestion d'incident
3. Structure d'un rapport d'incident
4. Résumé exécutif et communication
5. Analyse technique et evidence
6. Recommandations et plan d'action
7. Conformité juridique et réglementaire
8. Outils et bonnes pratiques

1. Enjeux et Contexte

Pourquoi documenter les incidents ?

Objectifs stratégiques :

- Traçabilité légale et réglementaire
- Communication claire vers décideurs et autorités
- Base pour amélioration continue
- Protection juridique de l'organisation

Objectifs opérationnels :

- Capitaliser les apprentissages
- Former les équipes
- Anticiper les futurs incidents

Objectifs techniques :

- Preuve pour investigations forensic
- Analyse des causes racines
- Support pour correctives actions

Audiences et leurs attentes

Audience	Horizon	Format	Détail
Direction	Réal + potentiel	Synthèse (1-2 p)	Impact, coûts, risques
RSSI/DSI	Technique	Détaillé (5-10 p)	Rootcause, IOC, technologie
Juridique	Conformité	Spécifique	Violations, réglementations
Autorités	Obligatoire	Selon format	Délai, notification
Assurances	Préjudice	Estimation	Damages, couverture
Équipes IT	Opérationnel	Procédures	Actions prises, leçons

Impact d'une mauvaise documentation

Juridique :

- Non-respect délai notification (RGPD = 72h)
- Absence de preuve en cas de litige
- Sanction par autorités

Organisationnel :

- Perte d'apprentissage
- Répétition des mêmes erreurs
- Pas de preuve de diligence

Technique :

- Difficulté à analyser causes racines
- Impossibilité de forensic
- Logs non archivés

Réputationnel :

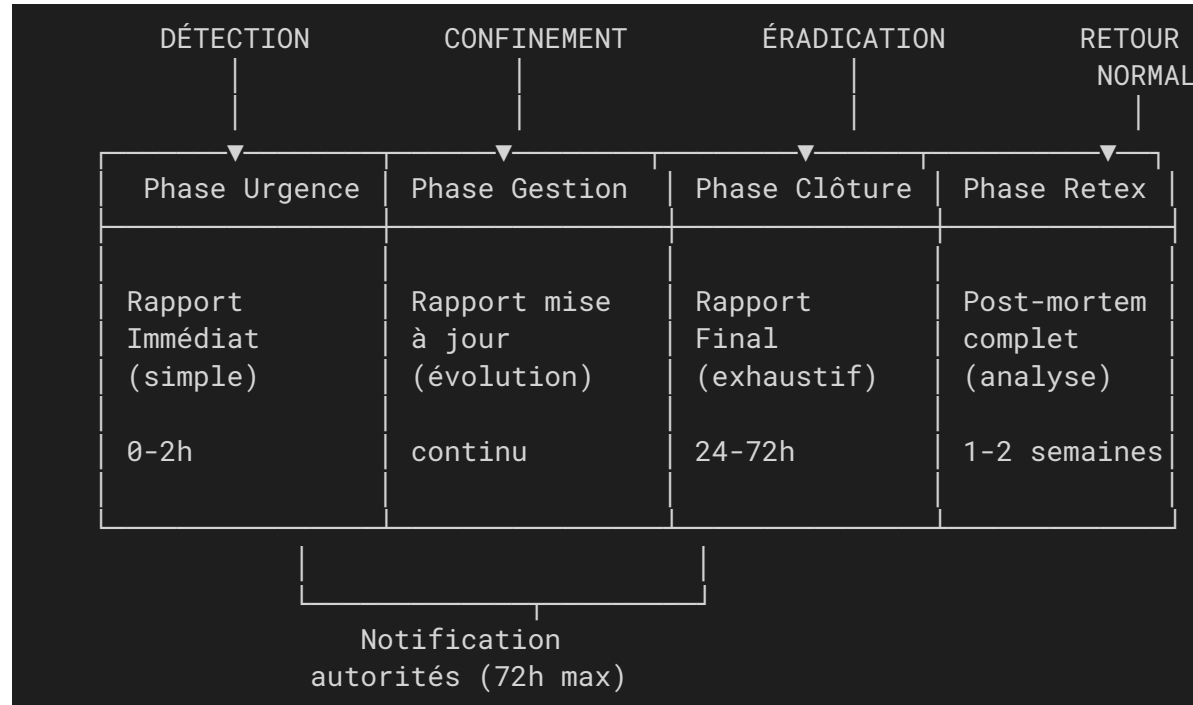
- Communications incohérentes
- Perte de confiance clients
- Médiatisation négative

Types de rapports

RAPPORTS D'INCIDENT	
RAPPORT IMMÉDIAT (< 4h) - Situation initiale - Actions d'urgence - Impact estimé - Contacts activés	RAPPORT FINAL (< 72h) - Analyse complète - Causes racines - Recommandations - Plan d'action
RAPPORT DE CRISE (< 48h) - Chronologie exhaustive - Décisions prises - Communications - Coordination cellule	POST-MORTEM (1-2 sem) - RETEX complet - Leçons apprises - Métriques - Améliorations futures

2. Phases de Rédaction dans la Gestion d'Incident

Chronologie rédaction vs incident



Phase 1 : Rapport Immédiat

Objectif : Communiquer RAPIDEMENT la situation.

Timing : 0-2h après détection

Contenu minimal :

- Quoi ? Incident type
- Quand ? Heure détection
- Où ? Systèmes affectés
- Impact estimé ? Nombre utilisateurs, services
- En cours ? Premiers éléments de contexte
- Responsable ? Contact de crise

Format : Email + Slack urgent

Exemple :

```
ALERTE INCIDENT INC-2025-042
Type : Cyberattaque - Ransomware
Déecté : 08:15 - Durée estimée : > 2h
Système : Serveur fichiers principal
Impact : 150 utilisateurs sans accès fichiers
Cellule : ACTIVÉE (N2)
Coordinateur : Marie DUPONT - 06 XX XX XX XX
Prochaine info dans 30 min
```

Phase 2 : Rapports de Suivi

Objectif : Suivre évolution, documenter actions.

Timing : Points toutes les 1-2h

Contenu :

- Situation actuelle
- Actions complétées depuis dernier rapport
- Actions en cours / bloquées
- Prochaines étapes
- Changements impact

Format : Template OneNote/Notion mise à jour en continu

Main courante :

Incident INC-2025-042 - Main courante

Heure	Événement	Action	Resp.	Statut
08:15	Alerte monitoring	Investigation	IT-SOC	En cours
08:30	Ransomware confirmé	Cellule activée	DG	Fait
08:45	Point #1	Isoler réseau	DSI	En cours
09:00	Réseau isolé	Analyser dégâts	RSSI	En cours
09:30	Point #2	Restauration backups	DBA	Planifié

Phase 3 : Rapport Final

Objectif : Documenter complètement l'incident CLOS.

Timing : 24-72h après clôture

Contenu exhaustif :

- Résumé exécutif
- Classification
- Chronologie complète
- Analyse technique
- Impact réel
- Actions de remédiation
- Recommandations
- Annexes (IOC, logs, preuves)

Format : Document officiel (Markdown + PDF)

Phase 4 : Post-Mortem (RETEX)

Objectif : Apprendre et améliorer processus.

Timing : 1-2 semaines après retour normal

Spécificités :

- Focus sur APPRENTISSAGE, pas blame
- Analyse causes racines 5 pourquoi
- Leçons positives et négatives
- Améliorations documentées

Participants :

- Équipes impliquées
- Management IT
- RSSI
- Métiers affectés

3. Structure d'un Rapport d'Incident

Structure générale - Table des matières

1. PAGE DE GARDE
 - Numéro incident
 - Titre
 - Dates
 - Classification
2. RÉSUMÉ EXÉCUTIF (1 page max)
3. CLASSIFICATION & CRITÈRES
 - Criticité
 - Impacts (C/I/A)
4. CHRONOLOGIE DÉTAILLÉE
5. ANALYSE TECHNIQUE
 - Vecteur d'attaque
 - Systèmes impactés
 - IOC
6. IMPACT & CONSÉQUENCES
 - Réel
 - Potentiel
 - Coûts
7. ACTIONS DE REMÉDIATION
8. RECOMMANDATIONS PRIORITAIRES
9. ANNEXES
 - Captures d'écran
 - Logs
 - Références techniques

1. Page de Garde

```
# RAPPORT D'INCIDENT
## Cyberattaque - Ransomware (Agents Tesla)

---
**Référence** : INC-2025-042
**Titre** : Phishing + Exécution Malware sur Poste Comptabilité
**Dates** :
- Détection : 5 mars 2025 - 08:15
- Clôture : 5 mars 2025 - 14:00
- Durée totale : 5h45
**Rédacteur** : Jean MARTIN, Analyste SOC
**Valideur** : Marie DUPONT, RPCA
**Date rédaction** : 6 mars 2025

**Classification** :
- Niveau de confidentialité : INTERNE
- Accès : Direction + RSSI + Juridique
- Archivage : 5 ans
**Numéro version** : 1.0 FINAL
```


2. Résumé Exécutif (Executive Summary)

Longueur : 200-300 mots maximum (1 page)

Doit répondre à :

Question	Réponse courte
Quoi ?	Type incident en 1 phrase
Quand ?	Heures détection/clôture + durée
Qui ?	Utilisateurs/systèmes affectés
Impact ?	Réel = CHIFFRES, Potentiel = GRAVITÉ
Cause ?	Vecteur attaque (phishing, etc)
Action ?	Isolation, restauration, etc
Coût ?	Estimation financière
Leçons ?	2-3 apprentissages clés

Exemple Résumé Exécutif

Résumé Exécutif

Un email de phishing contenant un malware Agent Tesla a été reçu par 13 collaborateurs le 5 mars 2025 à 07h45. Une collaboratrice du service Comptabilité (Marie DUBOIS) a ouvert la pièce jointe à 07h50.

****Impact réel** :**

- Aucune donnée exfiltrée (EDR + Firewall ont bloqué)
- Aucun accès non autorisé aux comptes
- Activité métier non affectée

****Impact potentiel** :**

- Vol des identifiants bancaires
- Accès aux systèmes clients
- Mouvement latéral réseau

****Réponse** :**

- Isolation du poste en 45 min
- Nettoyage complété en 6h
- Aucun incident secondaire

****Coût** :** 550€ (analyse 300€ + déploiement 100€ + productivité 150€)

****Leçons clés** :**

1. EDR + Firewall ont joué leur rôle de protection
2. Formation phishing insuffisante pour nouveaux arrivants
3. Onboarding doit inclure sensibilisation sécurité obligatoire

3. Classification de l'Incident

Matrice de classification :

Critère	Valeur	Impact
Criticité globale	2 - Moyen	Menace maîtrisée
Confidentialité	Non	Aucune donnée exfiltrée
Intégrité	Non	Aucune modification
Disponibilité	Oui	1 poste isolé temporairement
Type incident	Malware	Infostealer/Agent Tesla
Vecteur d'attaque	Email	Phishing + pièce jointe
Périmètre	Limité	1 poste + 12 emails reçus

3. Classification de l'Incident

Justification :

- Détection précoce (15 min)
- Bloquage automatique par EDR
- Aucune donnée sensible exposée
- Impact opérationnel minimal (1 utilisateur quelques heures)

4. Chronologie Détaillée

Format recommandé : Tableau avec source de chaque événement

Heure	Événement	Source	Details	Action	Responsable
07h45	Email phishing reçu	Logs Exchange	Objet "Facture impayée"	-	Attaquant
07h50	Pièce jointe exécutée	Témoignage	Fichier PDF.exe	-	M. DUBOIS
08h15	Alerte EDR	EDR Sophos	PowerShell suspect	Analyse	SOC
08h20	Investigation SOC	Analyste	Identification malware	Escalade	J. MARTIN
08h35	Malware identifié	VirusTotal	Agent Tesla (45/70)	Analyse	RSSI
08h40	Contact utilisateur	Téléphone	Confirmation ouverture	Isolation	DSI
09h00	Isolation réseau	Switch management	Déconnexion WKS-COMPTA-12	Confinement	DSI
09h15	Analyse forensic	Poste isolé	Tentatives C2 bloquées	Preuve	RSSI
09h30	Scan périmètre	Logs EDR	12 autres emails phishing	Alert	SOC
10h00	Nettoyage complet	Procédure	Suppression malware	Éradication	DSI
10h30	Restauration	Réinstall OS	Configuration sécurisée	Test	DBA
14h00	Retour production	Test accès	Validation utilisateur	Clôture	DSI

5. Analyse Technique

Vecteur d'Attaque

Vecteur : Phishing par Email

Description

Email apparemment professionnel prétendant venir du service comptabilité interne, avec demande urgente de traitement.

Détails techniques

- ****Expéditeur**** : comptabilite@financeecure.com (typo : "financeEcur")
- ****Objet**** : "Facture impayée - Action urgente"
- ****Pièce jointe**** : Facture_2024_003.pdf.exe
 - Double extension (PDF + EXE)
 - Taille : 2.3 MB
 - Signature malveillante détectée

Raison du succès

1. Contexte crédible (comptabilité)
2. Urgence implicite (facture impayée)
3. Double extension peut tromper utilisateurs
4. Domaine très similaire à domaine réel

5. Analyse Technique (suite)

Malware : Agent Tesla

****Famille**** : Infostealer bancaire

****Indicateurs de Compromission (IOC)**** :

Type	Valeur	Contexte
Hash SHA256	d3b07384d113edec49eaa6238ad5ff00	Fichier malveillant
Domaine C2	185.220.101.23	Serveur de commande
Port C2	4444	Communication C2
Chemin local	C:\ProgramData\WindowsUpdate\wuauserv.exe	Tentative persistance

****Comportements observés**** :

1. Exécution immédiate au lancement
2. Tentative vol cookies Chrome
3. Keylogger lancé (détecté avant activité)
4. Scanner réseau lancé
5. Connexion C2 initiée
6. Tentative copie persistance

****Techniques MITRE ATT&CK**** :

- T1566.001 - Phishing: Spearphishing Attachment
- T1059.001 - Command and Scripting Interpreter: PowerShell
- T1555 - Credentials from Password Stores
- T1071.001 - Application Layer Protocol: Web Protocols (C2)
- T1547.001 - Boot or Logon Autostart Execution: Registry Run Keys

5. Analyse Technique (suite)

Points de Blocage

Défenses ayant Fonctionné

Défense	Résultat	Impact
EDR Sophos	Alerte + blocage PowerShell	Limitant propagation
Firewall	Blocage connexion C2	Isolant du serveur malveillant
Signature antivirus	Détection 45/70 (VirusTotal)	Post-mortem seulement
Isolation rapide	45 min	Évitant mouvement latéral

Échecs / Améliorations

Élément	Problème	Amélioration
Filtrage email	Double extension non bloquée	Bloquer .exe même avec autre ext.
Formation	18 mois depuis dernière session	Cadence annuelle
Onboarding	Nouvelle arrivée sans formation	Formation obligatoire jour 1

6. Impact et Conséquences

Impact Réel

Données Exfiltrées

AUCUNE donnée n'a quitté le poste :

- Firewall a bloqué connexion C2
- Aucun trafic suspect détecté
- Logs authentication intacts
- Cookies session non volés
- Comptes utilisateur sécurisés

Impact Opérationnel

- ****1 poste indisponible**** : 5h45 (07h50 → 14h00)
- ****1 utilisateur impacté**** : Marie DUBOIS
- ****Services critiques**** : Aucun impact (comptabilité non critique en urgence)
- ****Autres utilisateurs**** : Aucun impact

Analyse Forensic

- ****Logs serveur**** : Aucune activité suspecte
- ****Logs réseau**** : 1 tentative C2 bloquée (185.220.101.23:4444)
- ****Temps avant blocage**** : < 2 minutes
- ****Activation malware**** : Confirmée, mais confinée

6. Impact et Conséquences (suite)

Impact Potentiel (Scénario Noir)

Si les défenses avaient échoué

1. ****Compromission comptes****

- Vol cookies session bancaire
- Accès compte client en tant que Marie
- Mouvement latéral via VPN comptabilité

2. ****Accès données sensibles****

- Factures clients
- Coordonnées bancaires
- Données financières confidentielles

3. ****Vol d'identité****

- Usurpation identité Marie auprès de clients
- Transactions frauduleuses

4. ****Escalade réseau****

- Scanner local aurait identifié autres cibles
- Tentative mouvement latéral vers serveurs

5. ****Impact réputation****

- Incident financier/bancaire = grave pour banque
- Notifications ACPR (régulateur)
- Perte confiance clients

6. Impact Financier

Coût de l'Incident

Élément	Durée	Coût unitaire	Total
----- ----- ----- -----			
Analyse SOC	6 heures	50€/h	300€
Réinstall poste	2 heures	50€/h	100€
Productivité perdue (Marie)	4 heures	37€/h	150€
TOTAL RÉEL			**550€**

Coût potentiel en cas d'exposition réelle

Scénario	Coûts
----- -----	
Analyse forensic approfondie	10-20K€
Notification clients obligatoire	5-10K€
Crédit monitoring (si données bancaires volées)	15-30K€
Amende ACPR (0,5-2% CA)	500K-2M€
Perte clients (si réputation)	Non mesurable
TOTAL POTENTIEL	**1-2.5M€**

****Coût évité grâce aux défenses**** : ~1-2M€

7. Actions de Remédiation

Actions déjà complétées :

Remédiation Immédiate (0-6h après détection)

Action	Heure	Resp.	Résultat
Isolation poste	09h00	DSI	WKS-COMPTA-12 déconnecté
Nettoyage malware	10h00	DSI	Suppression totale
Réinitial. password	10h15	IAM	Nouveau mot de passe généré
Revocation sessions	10h30	Appli bancaire	Fermeture sessions actives
Réinstallation OS	10h45	DSI	Image sécurisée déployée
Test restauration	13h00	QA	Validation complète
Retour production	14h00	DSI	Utilisateur opérationnel

Actions Correctives Court Terme (< 1 semaine)

Action	Statut	Deadline
Blocage domaine attaquant (financeecure.com)	Fait	08/03
Ajout hash malware antivirus	Fait	08/03
Blocage IP C2 (185.220.101.23)	Fait	08/03
Email sensibilisation collectif	Envoyé	06/03 14h30
Suivi poste (EDR + monitoring 30j)	En cours	04/04
Analyse complète forensic	Planifié	10/03

4. Résumé Exécutif et Communication

Art du résumé exécutif

Le résumé exécutif est CRITIQUE :

- Direction le lit EN ENTIER
- Autres ne lisent que ça (80% des lecteurs)
- Doit être AUTO-SUFFISANT
- Pas de jargon technique excessif

Règle d'or : "Une personne sans expertise technique doit comprendre"

Structure du résumé en 5 parties

1. SITUATION (1-2 lignes)

Quoi ? Quand ? Où ? Impact initial

2. CONTEXTE (3-4 lignes)

Pourquoi c'est arrivé ? Causes identifiées

3. RÉPONSE (3-4 lignes)

Qu'avons-nous fait ? En combien de temps ?

4. IMPACT (3-4 lignes)

Impact réel vs potentiel ? Chiffres !

5. LEÇONS (2-3 points)

Qu'avons-nous appris ? Prochaines étapes

Exemples : Bon vs Mauvais Résumé

Mauvais Résumé

Résumé Exécutif

Un incident de cybersécurité a été détecté le 5 mars. Il y avait un malware avec des IOC divers. L'EDR a bloqué le malware Agent Tesla. La situation est complexe avec plusieurs vecteurs d'attaque possibles. Des mesures techniques ont été prises. Plus d'info en page 8.

[Problèmes : trop vague, jargon, renvoi ailleurs, pas de chiffres]

Exemples : Bon vs Mauvais Résumé

Bon Résumé

Résumé Exécutif

Un email de phishing contenant un malware bancaire a été envoyé à 13 collaborateurs le 5 mars à 07h45. Une collaboratrice a ouvert la pièce jointe.

****Réponse**** : En 45 minutes, le poste a été isolé, le malware bloqué par nos défenses (EDR + Firewall), et aucune donnée n'a quitté l'organisation.

****Impact réel**** : 1 collaboratrice 5h45 sans accès, aucune donnée compromise.

****Coût**** : 550€ (analyse + déploiement + productivité).

****Apprentissages**** : Nos défenses techniques ont bien fonctionné. À améliorer : formation phishing pour nouveaux arrivants et filtrage emails sur doubles extensions.

Conseils de rédaction

Langage à utiliser

À privilégier :

- ✓ Phrases courtes (< 15 mots)
- ✓ Verbes actifs : "Nous avons isolé" vs "Le poste a été isolé"
- ✓ Chiffres concrets : "5h45" vs "longtemps"
- ✓ Structure logique : Quoi → Pourquoi → Comment → Résultat
- ✓ Expliquer acronymes : "EDR (détection d'anomalies endpoints)"
- ✓ Analogies si utile : "Comme un antivirus mais continu"

Conseils de rédaction

À éviter :

- x Jargon sans explication : "C2 beacon", "lateral movement"
- x Imprécision : "Peut-être compromis", "probablement"
- x Culpabilisation : "L'utilisateur a été stupide"
- x Dramatisation : "CATASTROPHIQUE!", "DRAME!"
- x Minimisation : "Ce n'était rien", "OK tout va bien"
- x Technicité excessive : Logs hex, captures mémoire RAM

Adaptations par audience

Pour la Direction

Pour le CODIR (1 page, 5 min)

TITRE : Cybersécurité - Incident Phishing Confiné

SITUATION : Email malveillant → 1 utilisateur impacté
5h45 (totalement résolu)

RÉPONSE : Défenses ont fonctionné, isolation en 45 min

COÛTS : 550€ (très faible)

RISQUES : Aucun (données protégées)

ACTIONS : Formation phishing renforcée + filtrage emails

DÉCISION DEMANDÉE : Approuver budget formation (5K€)

Adaptations par audience

Pour la Direction

Pour le RSSI

Pour le RSSI (10 pages, 30 min)

ANALYSE COMPLÈTE : IOC, techniques ATT&CK, logs

CAUSES RACINES : 3 causes identifiées

DÉTECTION : 15 min (excellent)

BLOQUAGES : EDR + Firewall (tous 2 ont joué)

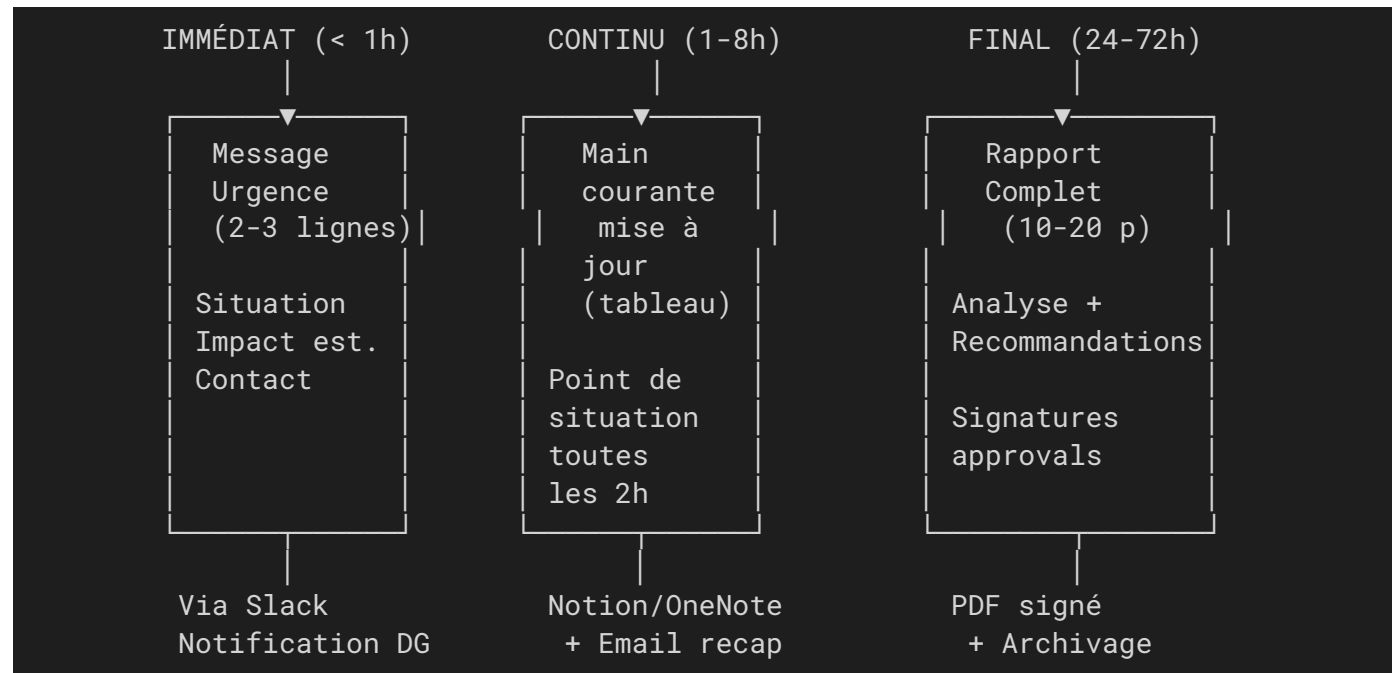
RECOMMANDATIONS : 7 recommandations prioritées

MÉTRIQUES : RTO 5h45, impact 0, détection 15 min

COMPARAISON : Benchmark vs autres incidents similaires

Communication progressive

Ne pas écrire le rapport complet d'un coup !



5. Analyse Technique et Evidence

Qu'est-ce qu'une bonne analyse technique ?

Objectifs :

- Expliquer COMMENT l'incident s'est produit
- Fournir PREUVES techniquement solides
- Permettre REPRODUCTION/INVESTIGATION
- Servir base pour CORRECTION

Pas d'analyse technique sans :

- Logs (firewall, EDR, applicatifs)
- Données forensic (hashes, timestamps)
- Schémas/diagrammes

Capture d'Evidence

Types de preuves à collecter :

Type	Exemple	Délai	Usage
Logs système	Logs Windows Event Viewer	Immediate	Timeline
Logs réseau	Firewall, proxy logs	< 1h	C2 identification
Logs applicatifs	Base données, app	< 2h	Impact data
Memory dump	RAM poste compromis	< 30min	Malware analysis
Fichiers malveillants	Binaires detects	< 15min	Forensic complet
Captures d'écran	Photos/screenshots	< 1h	Preuve visuelle
Témoignages	Interview utilisateurs	< 2h	Contexte humain

Structure d'une analyse technique

1. Vecteur d'Attaque Détaillé

```
## Vecteur : Email Phishing
```

```
### Analyse du message email
```

```
**Métadonnées email** :
```

```
- De : comptabilite@financeecure.com  
- Vers : marie.dubois@financesecure.com  
- Date d'envoi : 5 mars 2025 - 07h45:32 UTC  
- Message-ID : <...@financeecure.com>  
- Server origination : IP 185.220.101.15 (blocklisted)
```

```
**Analyse contenu** :
```

```
Objet : Facture impayée - Action urgente
```

```
Madame Dubois,
```

```
Nous constatons que la facture INC-2024-3847 de 12500€  
n'a pas été payée malgré l'échéance du 28 février.
```

```
Veuillez consulter et traiter le document joint sous 48h  
afin d'éviter des frais supplémentaires.  
Comptabilité
```

Structure d'une analyse technique

****Technique social engineering** :**

- Urgence (délai 48h)
- Menace (frais supplémentaires)
- Contexte crédible (facture + numéro)
- Domaine très similaire (financeEcure vs financeSecure)

Analyse pièce jointe

****Nom fichier** :** Facture_2024_003.pdf.exe

****Technique de déception** :**

- Double extension (utilise icône PDF mais exécutable EXE)
- Nom semblant professionnel
- Taille : 2.3 MB (peut charger gros payload)

****Analyse VirusTotal** :**

- 45 antivirus le détectent (63%)
- Verdict : Trojan.Dropper!C7
- Signature : Malware.Gen.2

2. Analyse Malware

Malware : Agent Tesla (Infostealer)

Identification

****Hashes** :**

- SHA256 : d3b07384d113edec49eaa6238ad5ff00
- MD5 : 5d41402abc4b2a76b9719d911017c592
- SHA1 : aaf4c61ddcc5e8a2dabede0f3b482cd9aea9434d

****Famille** :** Agent Tesla (aussi connu sous "Tesla Bot")

- Malware commercial (achat dans darknet)
- Prix : ~500-2000\$ la licence
- Utilisé par : cybercriminels russophone, asiatique

****Détails binaire** :**

- Taille non compressée : 2.3 MB
- Taille compressée : 890 KB
- Compiler : Visual Studio 2017
- .NET framework requis
- Signataire digital : Certificate volée (compromised)

2. Analyse Malware

Comportement observé

****Timeline d'exécution** :**

```
07h50 → Utilisateur double-clique PDF.exe
      ↓
07h50:05 → EDR alerte "Double extension suspicious"
      ↓
07h50:10 → Malware vérifie connexion internet
      ↓
07h50:15 → Tentative création directory persistence
      ↓
07h50:20 → EDR bloque PowerShell anonyme
      ↓
07h50:25 → Tentative copie dans C:\ProgramData\
      ↓
07h50:30 → Firewall bloque connexion C2 (185.220.101.23:4444)
      ↓
08h15 → EDR signale alerte → SOC notifié
```

3. Chaîne d'Attaque (Kill Chain)

Kill Chain - MITRE ATT&CK Framework

1. RECONNAISSANCE [T1592-Gather]
Attaquant scrape les annuaires publics pour
obtenir structure organisation + emails

↓

2. WEAPONIZATION [T1566.001]
Création email phishing avec leurre comptabilité +
malware Agent Tesla attaché

↓

3. DELIVERY [T1566.001]
Email envoyé via réseau SMTP compromis
À 13 adresses cibles (comptabilité)

↓

4. EXPLOITATION
Utilisateur ouvre PJ → Exécution EXE
[T1059.001 - PowerShell, T1047 - WMI]

↓

5. INSTALLATION [T1547.001]
Agent Tesla crée clé registry pour persistance
Copie dans C:\ProgramData\WindowsUpdate\
[BLOQUÉ par EDR]

↓

6. COMMAND & CONTROL [T1071.001]
Tentative connexion C2 vers 185.220.101.23:4444
[BLOQUÉ par Firewall]

↓

7. ACTIONS OBJECTIVES [T1555]
Exfiltration cookies, keylogging

4. Indicateurs de Compromission (IOC)

Indicateurs de Compromission (IOC)

****IOC Réseau** :**

Type	Valeur	Contexte	Action
IPv4	185.220.101.23	Serveur C2	Blockliste firewall
Port	4444	Port C2	Blocage ACL
Domaine	financeecure.com	Domaine phishing	Blocage DNS
MX record	mail.financeecure.com	Serveur email attaque	Blocage

****IOC Fichier** :**

Type	Valeur	Contexte
SHA256	d3b07384d113edec49eaa6238ad5ff00	Agent Tesla
MD5	5d41402abc4b2a76b9719d911017c592	Agent Tesla
Filename	Facture_2024_003.pdf.exe	Malware distribution
Path	C:\ProgramData\WindowsUpdate\wuau serv.exe	Persistence attempt

****IOC Email** :**

Type	Valeur
From	comptabilite@financeecure.com
Subject	Facture impayée - Action urgente
Message-ID	<INC-2025-042@financeecure.com>

****IOC Registry** (tentée) :**

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
Value: WindowsUpdate

4. Indicateurs de Compromission (IOC)

5. Logs et Preuves

Logs EDR (Sophos) :

```
[2025-03-05 07:50:15] Process Execution: cmd.exe
  Parent: explorer.exe
  CmdLine: powershell.exe -NoProfile -WindowStyle hidden -Command ...
  Status: BLOCKED (Suspicious PowerShell execution)
  Reason: Anomalous behavior + unsigned script
```

```
[2025-03-05 07:50:20] File System: Registry modification attempt
  Target: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
  Operation: SetValue (WindowsUpdate = C:\ProgramData\...)
  Status: BLOCKED (Persistence attempt detected)
```

```
[2025-03-05 07:50:25] Network Connection: Outbound TCP
  Source: WKS-COMPTA-12:52847
  Destination: 185.220.101.23:4444
  Protocol: TCP SYN
  Status: BLOCKED (Known C2 IP + suspicious port)
  Confidence: 95%
```

Logs Firewall :

```
2025-03-05 07:50:25 | IN | TCP |
  Source: 10.0.1.45 (WKS-COMPTA-12) | Port: 52847
  Destination: 185.220.101.23 | Port: 4444
  Action: DROP | Reason: Malicious IP (Threat Intel)
```

```
2025-03-05 07:50:30 | IN | TCP |
  Source: 10.0.1.45 | Port: 52848
  Destination: 185.220.101.23 | Port: 4444
  Action: DROP | Count: 3 retries
```

Logs DNS (Proxy) :

```
07:50:15 | WKS-COMPTA-12 | financeecure.com | 185.220.101.15 | ALLOWED
  (No filtering at time - now blocked)
```


Schéma d'attaque



6. Recommandations et Plan d'Action

Formulation de bonnes recommandations

Caractéristiques d'une bonne recommandation :

Spécifique

: "Bloquer les exécutable EXE au niveau proxy email" (pas "sécuriser email")

Mesurable

: "100% des EXE bloqués" ou "0 double-extensions passées"

Acceptable

: Réaliste budget/ressources, pas trop coûteux pour impact

Réaliste

: Faisable techniquement dans l'infrastructure actuelle

Temporelle

Matrice de priorisation

IMPACT		Haute (5h min)	Basse (< 1h)
URGENCE	Haute (1 sem)	P1 Immédiat	P2 Important
	Basse (1 mois)	P2 Important	P3 Souhaitable

Exemple Matrice :

Template de recommandation

```
## Recommandation N°1 : Filtrage avancé des pièces jointes email

**Priorité** : P1 (Critique)

**Justification** : Cet incident aurait pu être évité si les
fichiers exécutables et les double-extensions avaient été bloqués
à la passerelle email. C'est le vecteur attaque le plus courant
(60% des incidents).

**Spécification technique** :

Déployer filtre avancé sur passerelle email (Proofpoint,
Mimecast ou équivalent) pour :

1. **Bloquer** exécutables directs : .exe, .com, .scr, .bat, .cmd
2. **Bloquer** archives suspects : .zip, .rar avec EXE inside
3. **Bloquer** double-extensions : *.*.exe, *.pdf.exe, etc
4. **Détecter** pattern phishing : domaines similaires (-1 char)
5. **Alerter** administrateurs email pour review/unblock demandes

**Impact** :
- Élimine 90% des vecteurs phishing+malware
- Faux positifs estimés : < 0.1% (whitelist gérable)
- Productivité : Aucun impact (alternatives légales disponibles)

**Coûts estimés** :
- Solution : 15 000€/an (Proofpoint Advanced Threat Protection)
- Déploiement : 5 jours consultant (5 000€)
- Formation IT support : 1 jour (1 000€)
- **Total année 1** : ~21 000€
- **Années suivantes** : 15 000€/an

**Bénéfice**:
- Incidents évités : 10/an × 50k€ impact moyen = 500 000€
- **ROI** : 23x la 1ère année, infini ensuite
```

Exemple : 7 Recommandations Priorisées

Plan d'Action Post-Incident

P1 - À faire immédiatement (< 1 semaine)

#	Action	Coût	Délai	Resp.	Bénéfice
1	Bloquer EXE et double-ext. email	21k€	2 sem	DSI	ROI 23x
2	Former phishing annuel ALL	8k€	1 sem	RH	-70% vuln.
3	Test restoration backup mensuel	0€	1 sem	DBA	Assurance
4	Audit EDR coverage (100%)	5k€	2 sem	RSSI	Détection

P2 - À faire rapidement (< 1 mois)

#	Action	Coût	Délai	Resp.
5	Déployer MFA sur accès sensibles	45k€	4 sem	IAM
6	Rédiger/mettre à jour onboarding sécu	3k€	3 sem	RSSI
7	Revoir incident response playbook	2k€	2 sem	RPCA

P3 - À planifier (1-3 mois)

#	Action	Coût	Délai
8	Simulation phishing trimestrielle	12k€	Trimes.
9	Formation ANSSI cyber avancée	15k€	Annuel
10	Architecture zero-trust	150k€	6 mois

****Budget Total 2025**** : ~111 000€

Actions par domaine

Actions Correctives par Domaine

1. TECHNIQUE

- [] Bloquer EXE + double-ext email (P1, 2 sem)
- [] Déployer EDR 100% endpoints (P1, 4 sem)
- [] Configurer alertes timeouts connexion (P2, 1 sem)
- [] Test monthly backup & restoration (P1, continu)
- [] Network segmentation (comptabilité isolée) (P2, 2 mois)
- [] Upgrade firewall (add IPS capability) (P3, 3 mois)

2. HUMAIN (Formation)

- [] Formation phishing annuelle ALL staff (P1, 3 mois)
- [] Onboarding sécu jour 1 pour ALL new (P1, 1 mois)
- [] Certification ISO 27001 pour IT (P2, 6 mois)
- [] Sensibilisation dirigeants (email/phishing) (P2, 1 mois)

3. PROCESSUS

- [] Incident response playbook update (P1, 2 sem)
- [] Communication crise template (P1, 1 sem)
- [] Runbook confinement ransomware (P2, 3 sem)
- [] Backup restoration procedure (P1, 1 sem)

4. ORGANISATIONNEL

- [] Renforcer équipe SOC (+1 FTE) (P2, recrutement 3 mois)
- [] Créer RSSI adjoind (P2, recrutement 2 mois)

7. Conformité Juridique et Réglementaire

Cadre légal : Notifications d'incident

En France / UE :

Régulation	Délai	Obligations
RGPD	72h	Notifier CNIL si données personnelles
NIS 2	24h (opérateurs critiques)	Autorités compétentes
Secteur bancaire	24h ACPR	Régulateur
Santé	15 jours	CNIL + patients
Énergie	3 jours	Régulateur

Notification RGPD (France)

Procédure Notification RGPD

1. Déterminer si données personnelles compromises

Poser les questions :

- Données = emails, noms, téléphones, ID clients ?
- Données = données bancaires/sensibles ?
- Si OUI à l'une des 2 → notification obligatoire

2. Notifier CNIL (délai 72h)

****Contenu minimum** :**

- Nom/coordonnées Responsable traitement
- Description incident
- Données concernées (combien d'individus)
- Conséquences probables
- Mesures prises ou proposées

****Format** :** Formulaire CNIL ou email legal@cnil.fr

****Preuve** :** Numéro enregistrement CNIL

3. Informer les concernés (sans délai si risque élevé)

****Contenu** :**

- Nature du risque
- Mesures d'atténuation
- Contact pour questions

****Exceptions**** (pas besoin d'informer) :

- Données chiffrées de manière sûre

Éléments légaux à documenter

Checklist Conformité Juridique

En cas de cyberattaque confirmée

- [] Incident numéro unique (INC-AAAA-NNN)
- [] Date/heure précise détection
- [] Date/heure clôture
- [] Responsables impliqués (noms)
- [] Systèmes affectés (liste complète)
- [] Données compromises (type + volume)
- [] Impact réel vs potentiel
- [] Éléments de preuve (logs, hashes)
- [] Notification CNIL (ou justif. exemption)
- [] Communication autorisée par DG+Juridique
- [] Contrat assurance cyber (notifié à assureur)
- [] Contrats prestataires (droits investigation)

Documentation requise

- [] Main courante datée signée
- [] Rapports techniques détaillés
- [] Traces forensic préservées
- [] Screenshots/captures
- [] Emails communications (internal + externe)
- [] Décisions prises + justification
- [] Budget débloqué et approuvé
- [] Interviews utilisateurs

Archivage

- [] Rapport PDF signé électroniquement
- [] Stockage sécurisé (5 ans minimum)

Protection du rapport

Privilège Avocat / Attorney-Client Privilege

Rapport confidentiel (RECOMMANDÉ)

Si rapport préparé par/avec Avocat :

- Peut être marqué "CONFIDENTIEL - PRIVÉ"
- Peut être "travail avocat" = NON découvrable
- En cas litige, peut ne pas être produit

****Comment invoquer le privilège** :**

CONFIDENTIEL - TRAVAIL AVOCAT

Ce rapport a été préparé à la demande de [Avocat X]

Obligations spécifiques par secteur

Banque / Finance

Incident Bancaire - Obligations ACPR

****Délai notification**** : 24h

****Contenu**** :

- Incident description
- Systèmes critiques affectés
- Impact clients/opérations
- Durée de l'incident
- Mesures d'atténuation
- Analyse causes racines prévu

****Escalade**** :

- Reportage audit interne

Déclaration d'incident vs. Rapport

DÉCLARATION INCIDENT (ALERTE RAPIDE) Vers : CNIL (RGPD), ACPR (Banque), ANSSI (All) Délai : 24-72h (dépend secteur) Format : Email ou portail gouvernemental Longueur : 1-2 pages Contenu minimal : - Situation initiale - Données touchées (estimé) - Mesures d'urgence prises - Contact pour plus d'infos	
↓	
RAPPORT COMPLET (INVESTIGATION COMPLÈTE) Vers : Même autorités (suivi déclaration) Délai : 15-30 jours après clôture Format : PDF signé + certifié Longueur : 10-30 pages Contenu exhaustif : - Analyse causes racines - Données RÉELLES touchées - IOC complet - Recommandations futures - Preuves techniques	

8. Outils et Bonnes Pratiques

Outils de rédaction

Stack Recommandé

Documentation

Outil	Usage	Avantages	Inconvénients
Notion	Main courante collab	Real-time, partagé	Export PDF moyen
OneNote	Points situation	Offline capable	Moins beau
Markdown	Rapports techniques	Version control git	Besoin conversion PDF
Google Docs	Rapport final	Collaboration facile	Trace possible (Google)
Word + PDF	Rapport signé	Standard entreprise	Lourd, inflexible

****Recommandation**** : Markdown + Pandoc pour PDF signé

Gestion de contenu

Outil	Usage
Git/GitHub	Versioning rapports + historique
SharePoint	Archivage long terme
Vault/Keeper	Secrets dans rapport (hashes, etc)

Diagrammes

Outil	Type
Draw.io	Kill chain, architecture
Lucidchart	Fluxes complexes

Template de rapport

Où le trouver :

```
## Structure Minimale Template

### Headers Markdown

```markdown
Rapport d'Incident INC-AAAA-NNN

1. Résumé Exécutif

2. Classification

3. Chronologie

4. Analyse Technique

5. Impact et Conséquences

6. Actions de Remédiation
```

# Bonnes pratiques rédaction

## ## Do's and Don'ts

### ### À FAIRE ✓

- ✓ Phrases courtes (< 15 mots)
- ✓ Voix active : "Nous avons isolé"
- ✓ Chiffres concrets : "5h45", "150 utilisateurs"
- ✓ Expliquer terminologie : "EDR (Endpoint Detection)"
- ✓ Structurer avec bullet points et tableaux
- ✓ Exemples concrets : "Malware xyz faisait ceci"
- ✓ Preuves attachées : "Voir annexe A - logs firewall"
- ✓ Leçons positives ET négatives
- ✓ Recommandations SMART (5 critères)
- ✓ Différencier réel vs potentiel

### ### À ÉVITER ✗

- ✗ Jargon excessif : "T1078.004 exploitation IAM"
- ✗ Imprécision : "Peut-être compromis", "On pense que"
- ✗ Culpabilisation : "Utilisateur stupide"
- ✗ Dramatisation : "CATASTROPHE!", "DÉVASTATEUR"
- ✗ Minimisation : "C'était rien", "Pas important"
- ✗ Blame culture : "C'est la faute de..."
- ✗ Problèmes non documentés : Aucune suspicion
- ✗ Recommandations sans coûts : "Implémenter zéro trust"
- ✗ Rapports génériques : "Copier/coller précédent"

# Cycles de révision

## ## Process de Validation

T+1h → Brouillon initial (POC incident)

Rédacteur : Analyste SOC

Review : Aucun (information interne)

T+6h → Rapport d'incident complet

Rédacteur : RSSI + Analyste SOC

Review : DSI + Juridique

Signature : RPCA

Distribution : Direction + RSSI

T+72h → Rapport final (post-clôture)

Rédacteur : RSSI

Review : DSI + Juridique + DG

Signature : RPCA + DG + Juridique

Archive : SharePoint (5 ans)

Notification autorités : Si applicable

T+2 sem → Post-Mortem/RETEX

Rédacteur : RPCA + Équipes

Review : Aucun (interne, apprentissage)

# 9. Exercices Pratiques

# Exercice 1 : Résumé Exécutif

## Scénario :

Panne SQL Server 12h, 500 utilisateurs impactés, restauration backup réussie, aucune donnée perdue, coût 2000€ (DBA + test).

## À faire (20 min) :

1. Rédiger résumé exécutif en 250 mots max
2. Inclure : Quoi, Quand, Impact, Réponse, Coûts, Leçons
3. Destinataire : CODIR (PDG + CFO + DSI)

## Critères succès :

- Pas de jargon technique

# Exercice 2 : Chronologie Réaliste

## Scénario :

```
08:00 - Utilisateur ne peut pas ouvrir fichiers
08:15 - IT support reçoit appel
08:30 - DSI remarque processus suspect sur serveur
08:45 - Ransomware identifié (LockBit)
09:00 - Cellule de crise activée
09:15 - Décision : isoler serveur
09:30 - Serveur isolé
10:00 - Analyse forensic commence
11:30 - Autres serveurs vérifiés (aucune compromise)
12:00 - Backup restauré du jour précédent
14:30 - Services opérationnels à 80%
15:00 - Services 100%
```

À faire (20 min) :

## Exercice 3 : Recommandations SMART

### Scénario :

3 incidents similaires en 6 mois = ransomware via email.

### À faire (30 min) :

Rédiger 5 recommandations pour éviter futur incident :

1. **P1** : Filtrage email (vecteur principal)
2. **P1** : Formation phishing
3. **P2** : Segmentation réseau
4. **P2** : EDR déploiement
5. **P3** : Exercice simulation

# Exercice 4 : Analyse Technique Minimale

## Scénario :

Malware détecté via EDR sur poste utilisateur.

Hash SHA256 : abc123...

IP C2 : 192.168.1.100

Fichier : malware.exe (2 MB)

## À faire (45 min) :

1. Faire recherche VirusTotal sur hash
2. Rédiger analyse malware :
  - Famille + type



# Exercice 5 : Rapport Complet (Groupe)

**Scénario** : Cas réel simplifié

Incident : Accès non-autorisé base de données clients  
(1000 emails volés).

**Travail par groupe** (2-3 personnes, 2h) :

1. Rédiger rapport complet (10-15 pages) avec sections :

- Page de garde
- Résumé exécutif (1 page)
- Classification
- Chronologie (8-10 événements)

## Exercice 6 : Présentation CODIR (5 min)

### Scénario :

Vous présentez incident à direction (PDG + CFO + DG RH).

**À faire** (20 min préparation) :

1. Préparer slides (3-4 maximum) :

- Situation en 30 sec
- Impact chiffré (30 sec)
- Réponse et délai (30 sec)
- Prochaines étapes (30 sec)

2. Préparer réponses aux questions :

# Solutions Exercices

## Exercice 1 - Exemple Résumé

### ## Résumé Exécutif

Le serveur SQL principal s'est arrêté subitement le 15 mars à 08:00, rendant inaccessibles les données pour 500 utilisateurs (15% de la base).

Cause identifiée : Corruption disque due à défaut matériel (SMART alert détecté a posteriori).

Réponse : Restauration depuis backup complet d'hier (23h00).  
Tous les services restaurés à 15:00 (durée totale : 7 heures).

Impact réel : 0 données perdues (backup automatique fonctionnait). Aucun client n'a été affecté (services non-client pas critiques).

# Ressources

## ## Frameworks et Standards

- **\*\*ISO 27035\*\*** : Information security incident management
- **\*\*NIST SP 800-61\*\*** : Computer Security Incident Handling
- **\*\*SANS Incident Handler's Handbook\*\***
- **\*\*MITRE ATT&CK\*\*** : Framework techniques adversaire

## ## Outils

- **\*\*VirusTotal\*\*** : Identification malware
- **\*\*MISP\*\*** : Partage IOC
- **\*\*Sigma Rules\*\*** : Détection generic
- **\*\*Yara\*\*** : Pattern matching malware

## ## Modèles Templates

- **\*\*CISA Incident Reporting\*\*** : gov template
- **\*\*SANS Template\*\*** : Format professionnel

# Questions ?